

Cybersecurity

Applied Cryptography and Attacks

Lesson 11.3



Learning Objectives

By the end of today's lesson, you will be able to:

- 1 Apply steganography in order to hide a message within non-secret data, such as an image.
- 2 Use SSL certificates to help authenticate a website.
- 3 Use cryptographic attack methods to crack a password.
- 4 Use Hashcat to uncover the plaintext value of a hash.



Welcome

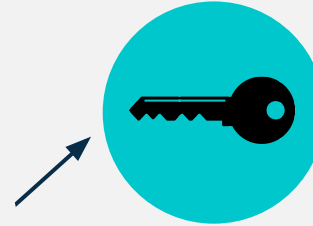
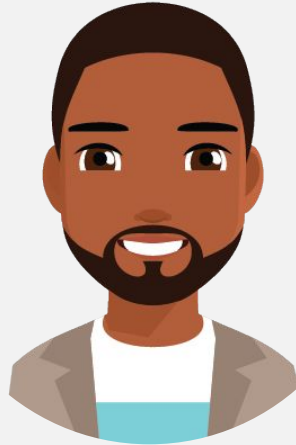


Let's Recap

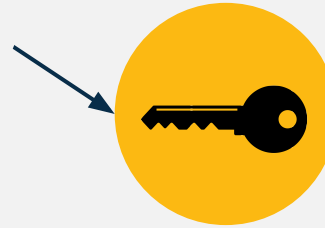
Asymmetric Key Encryptions

While symmetric encryption has many advantages, its primary disadvantages are key exchange and key management.

As an alternative, we can use asymmetric key encryption—also known as public-key encryption—in which each individual has a two-key pair.



Private keys are kept secret and can affect confidentiality of messages if exposed.

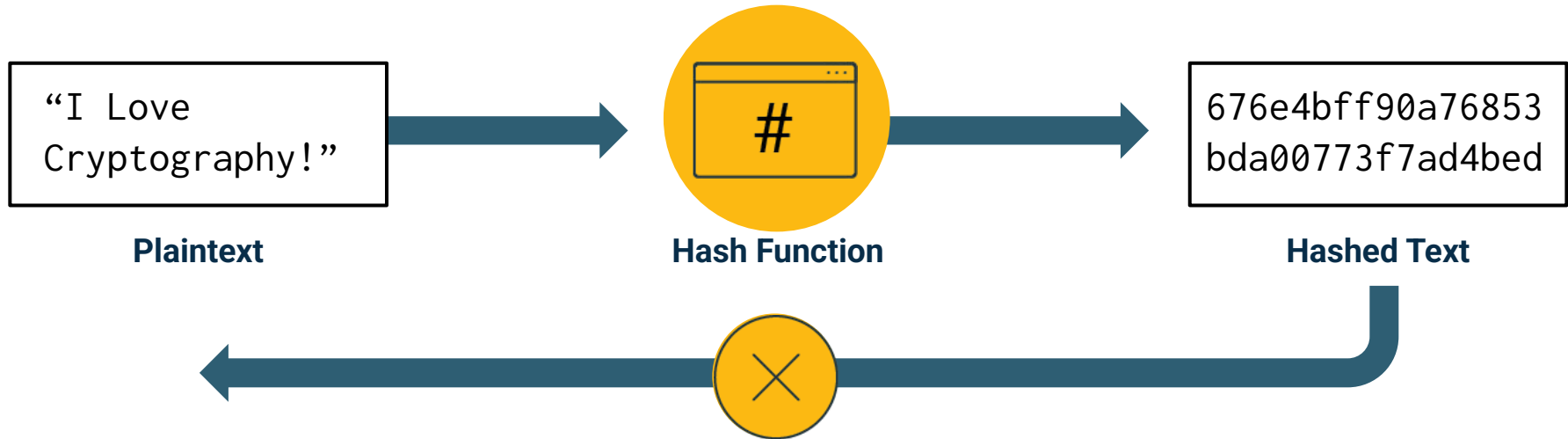


Public keys are public and accessible to all.

Hashing

While encryption is used to protect confidentiality, hashing is a cryptographic method used to protect integrity.

Hashing uses algorithms to convert a plaintext message into a message digest, also known as a hash.



Hashing is a **one-way function**, meaning it cannot be converted back to plaintext.

Digital Signatures

A digital signature is a mathematical scheme used to verify the authenticity of digital data.

Like encryption, digital signatures use public key cryptography.

However, a user uses their own private key to sign a document, and the public key is used by other users to validate the signature.





Questions?





Activity

Cryptography refresher

You will continue to act as a security analyst working for the Hill Valley Police Department.

In this review activity, you will create a plaintext message and ClearSign it using GPG.

Suggested Time
20 minutes



Questions?





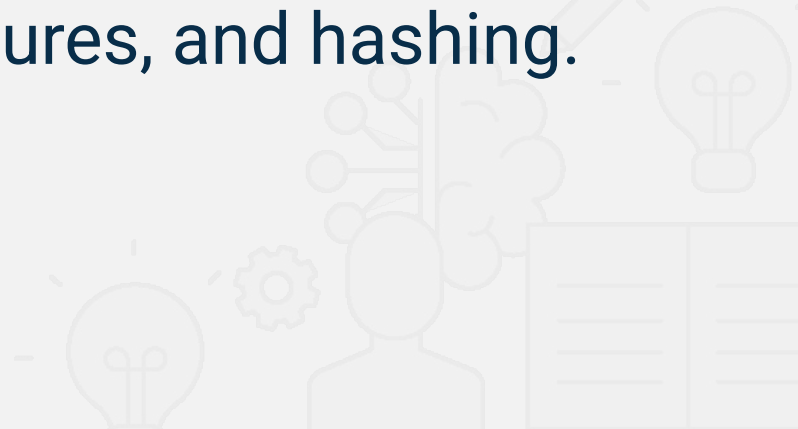
Time's Up!
Let's review



Introduction to **Applied Cryptography**



So far, we have covered many cryptographic concepts, such as encryption, public key cryptography, digital signatures, and hashing.



Artificial Intelligence and Cryptography

AI can provide many benefits within cryptography:

Analyzing Crypto Systems

Cryptographers can analyze existing cryptography systems with AI.

AI can be utilized to develop stronger encryption algorithms.



Generation of Secure Keys

AI can be used to generate and develop keys with a high level of randomness.



Homomorphic Encryption and Data Privacy

A form of AI encryption where data can be analyzed and shared without decryption occurring first.



Cryptography and Portable Devices

Encryption can be used to secure portable devices like laptops and cell phones.

BitLocker

Microsoft Windows uses a symmetric disk encryption program called **BitLocker**.



FileVault

Macs use a symmetric disk encryption program called **FileVault**.



Cryptography and Email

Encryption can be used to secure emails.

Emails are not natively encrypted and can therefore be sent and received in plaintext.

Programs such as **S/MIME** and **PGP** are used to make emails confidential by applying public key cryptography.



Cryptography and Websites

Encryption can be used to secure emails.

SSL (secure socket layer)

is a protocol designed to provide encryption for web traffic.

- HTTPS

SSL certificates are “seals of approval” for websites.



Cryptography and Websites

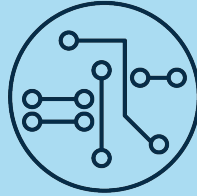
Websites use hashing to store passwords.

Storing passwords in plaintext comes with risks, such as exposing:

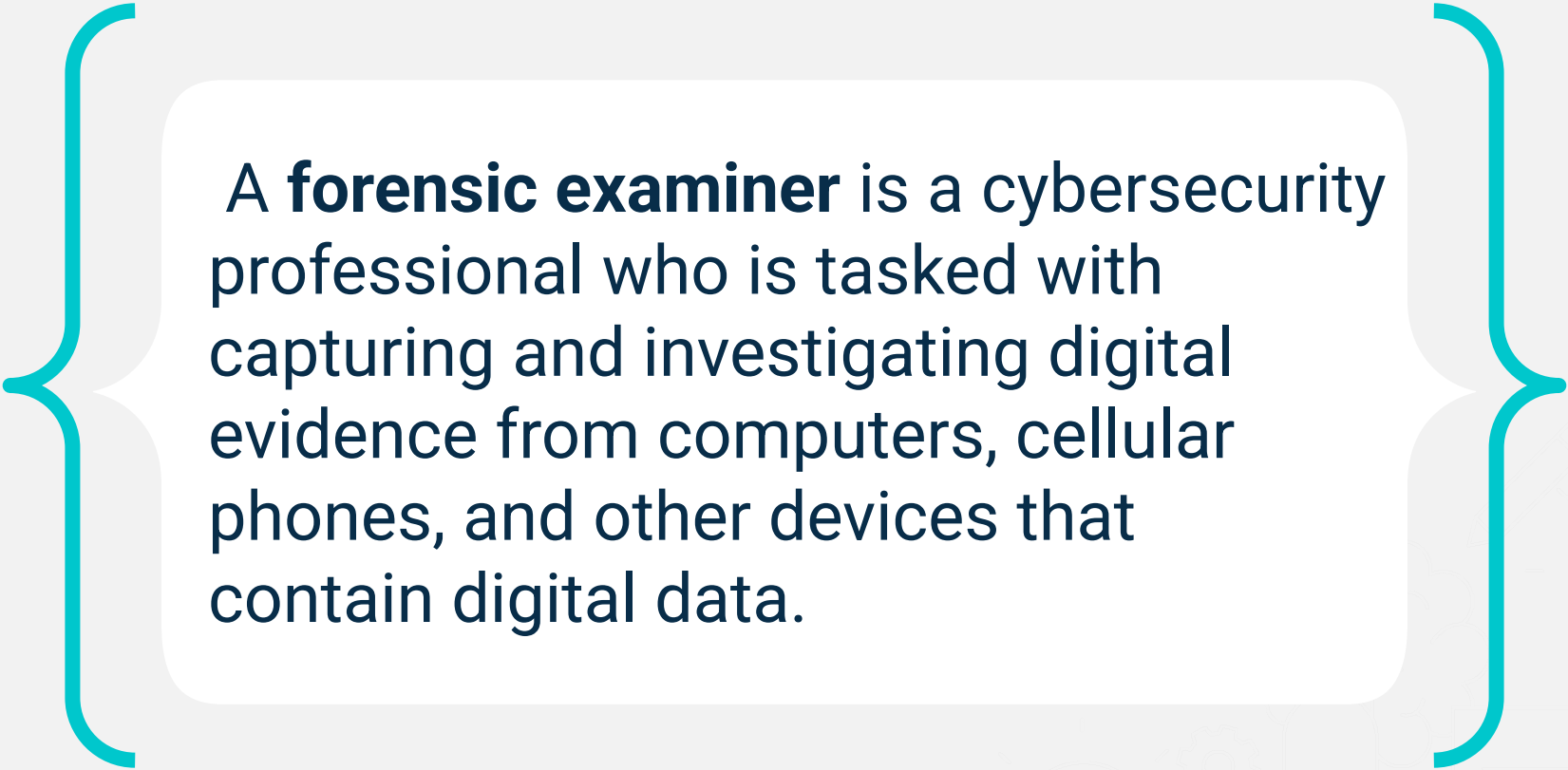
- Usernames
- Passwords

Websites defend against this by hashing passwords.





Digital Forensics and Steganography



A **forensic examiner** is a cybersecurity professional who is tasked with capturing and investigating digital evidence from computers, cellular phones, and other devices that contain digital data.



Evidence is
used in private
industry and
public legal
and criminal
investigations.

Digital Forensics

Hashing

Forensic examiners often apply **hashing**.

For example:

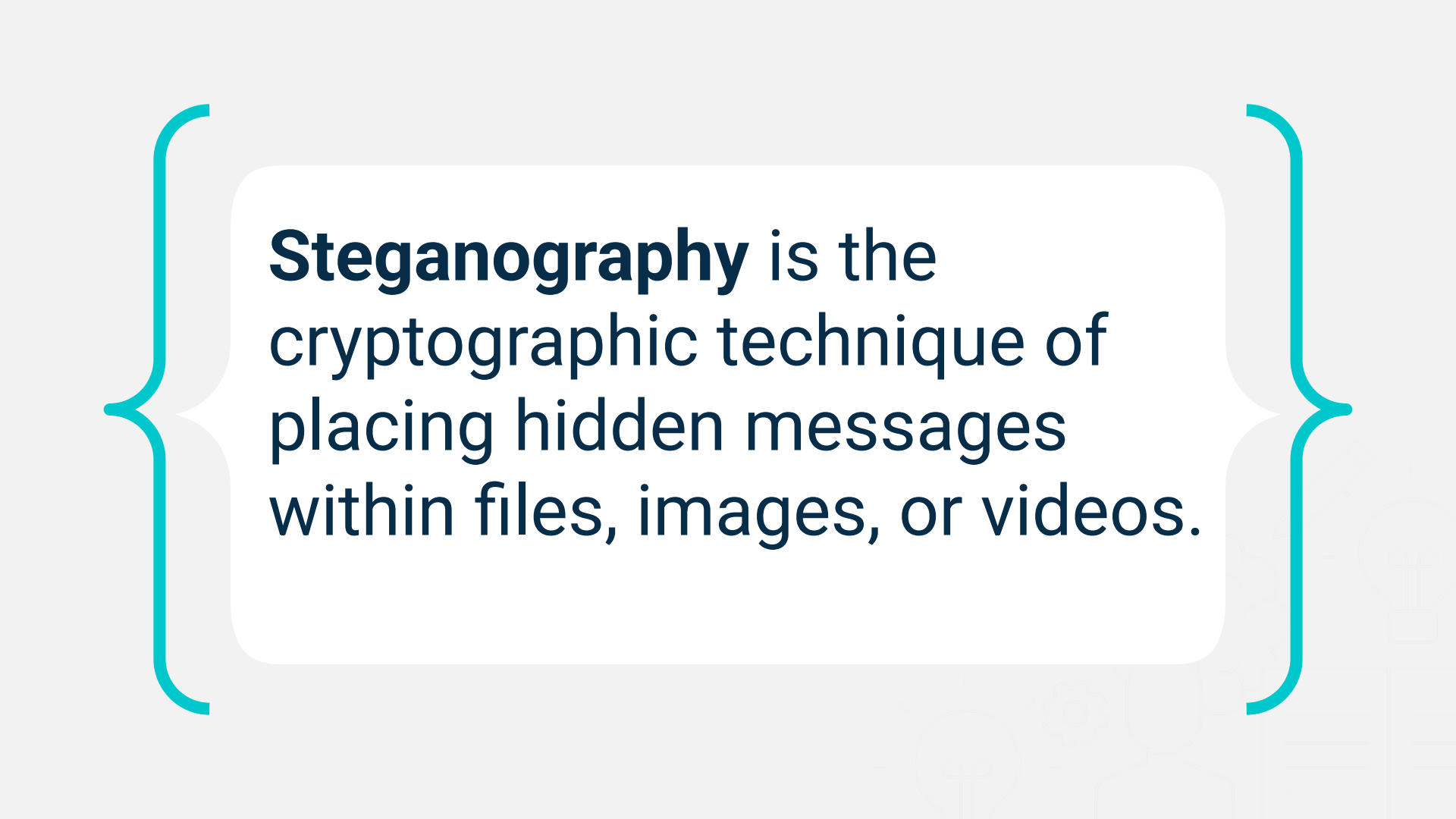
If a forensic examiner collects a hard drive from a laptop for an investigation, the examiner will immediately create a hash of the laptop.

The hash can be later used to verify that the digital data was not modified during the investigation.

EVIDENCE	
Agency _____	Case No. _____
Item No. _____	Time of Collection _____
Date of Collection _____	Collected By _____
Description of Evidence _____	
Location of Collection _____	
Type of Offense _____	
Victim _____	
Suspect _____	

CHAIN OF CUSTODY	
Received From _____	By _____
Date _____	Time _____
Received From _____	By _____
Date _____	Time _____
Received From _____	By _____
Date _____	Time _____

EVIDENCE



Steganography is the cryptographic technique of placing hidden messages within files, images, or videos.

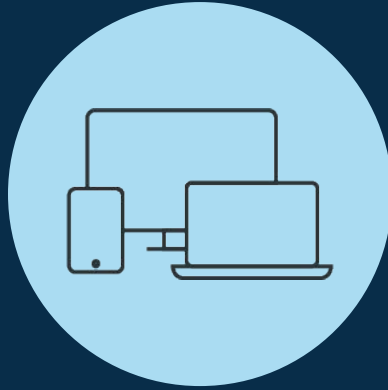


Demonstration Scenario



A forensic investigator can investigate an employee suspected of selling insider trading information.

- The employee has no obvious or suspicious files, only family photos.
- The investigator can apply steganographic tools to analyze these photos for hidden data.



Instructor Demonstration

steghide

Digital Forensics and Steganography Summary

- Cryptographic concepts such as encryption, public key cryptography, and hashing have many modern day applications.
- Operating systems often use symmetric encryption programs.
- Emails can use tools such as PGP and S/MIME.
- Websites use public key cryptography to establish a secure session.
- Forensic examiners use hashing to prove the integrity of the digital data they collect.
- Steganography is a cryptographic technique used to hide data.



Questions?





Activity

Steganography

You will continue in the role of a security analyst working for the Hill Valley Police Department.

- The Alphabet Bandit left a thumb drive that only contained a JPG image of a car.
- You must use steganography tools to determine if the image contains any hidden messages.

Suggested Time
15 minutes



Time's Up!
Let's review

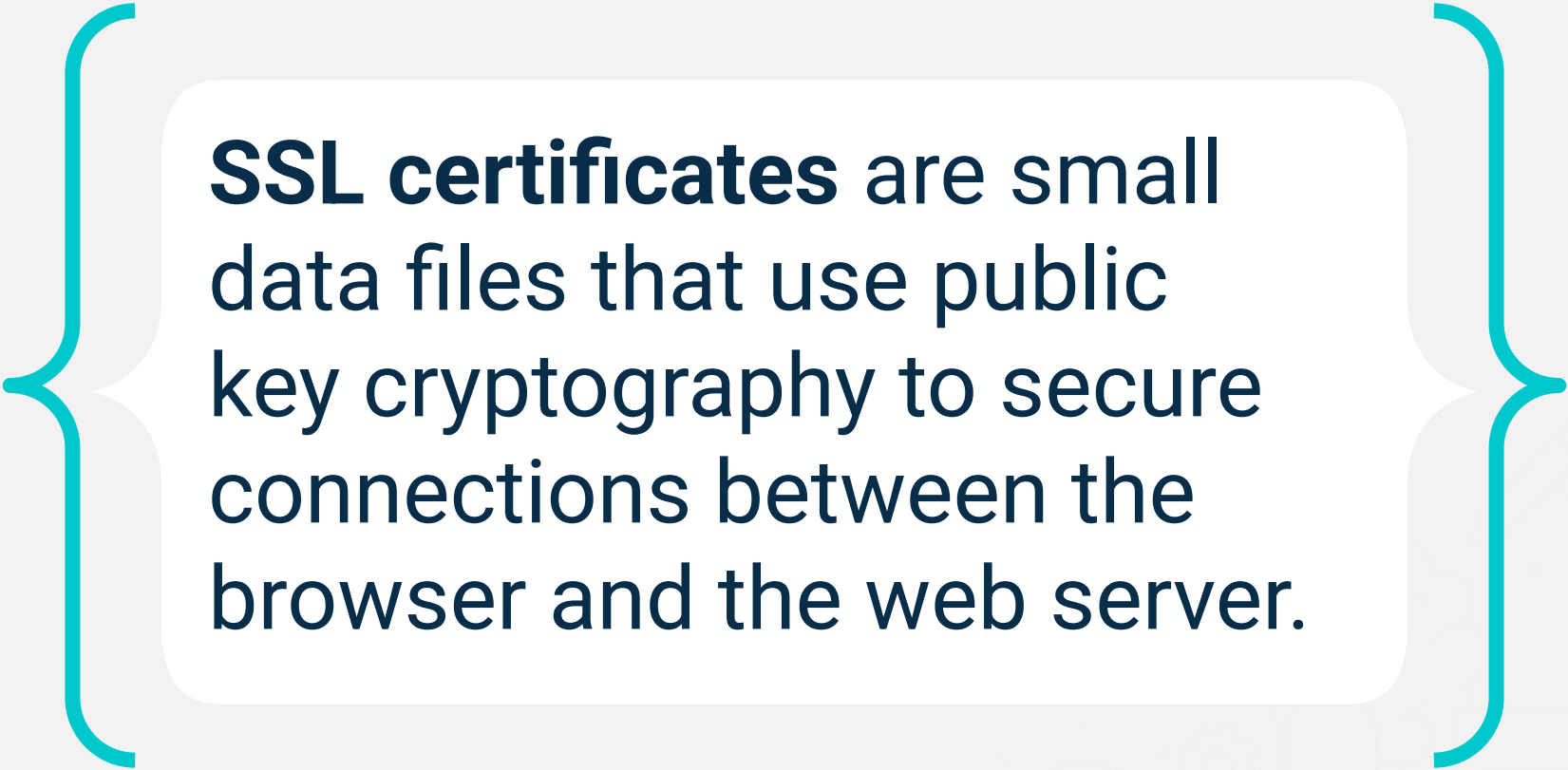


Questions?





SSL Certificates



SSL certificates are small data files that use public key cryptography to secure connections between the browser and the web server.

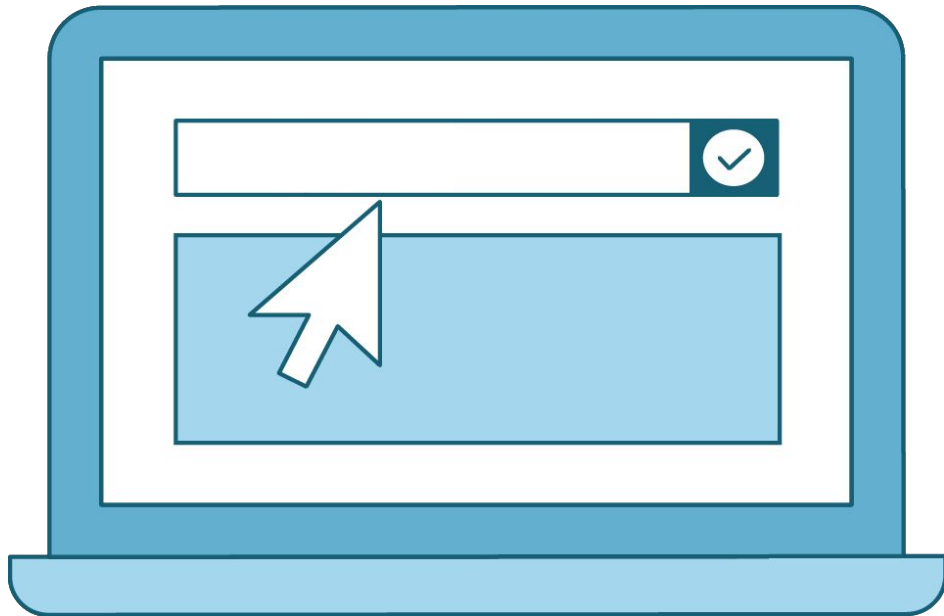


Scenario

Widgets Corp

We will walk through the process of acquiring an SSL certificate for **widgets.com**.

- SSL certificates can assist websites by providing them with authentication and confidentiality.





Obtaining an SSL Certificate

Step 1: Certificate authority



To get an SSL certificate, an organization must first reach out to a **certificate authority (CA)**, an organization responsible for issuing SSL certificates.

widgets.com will request an SSL certificate called an **X.509 certificate**.



An **X.509 certificate** is the current standard of SSL certificates for securing online communications.



Obtaining an SSL Certificate

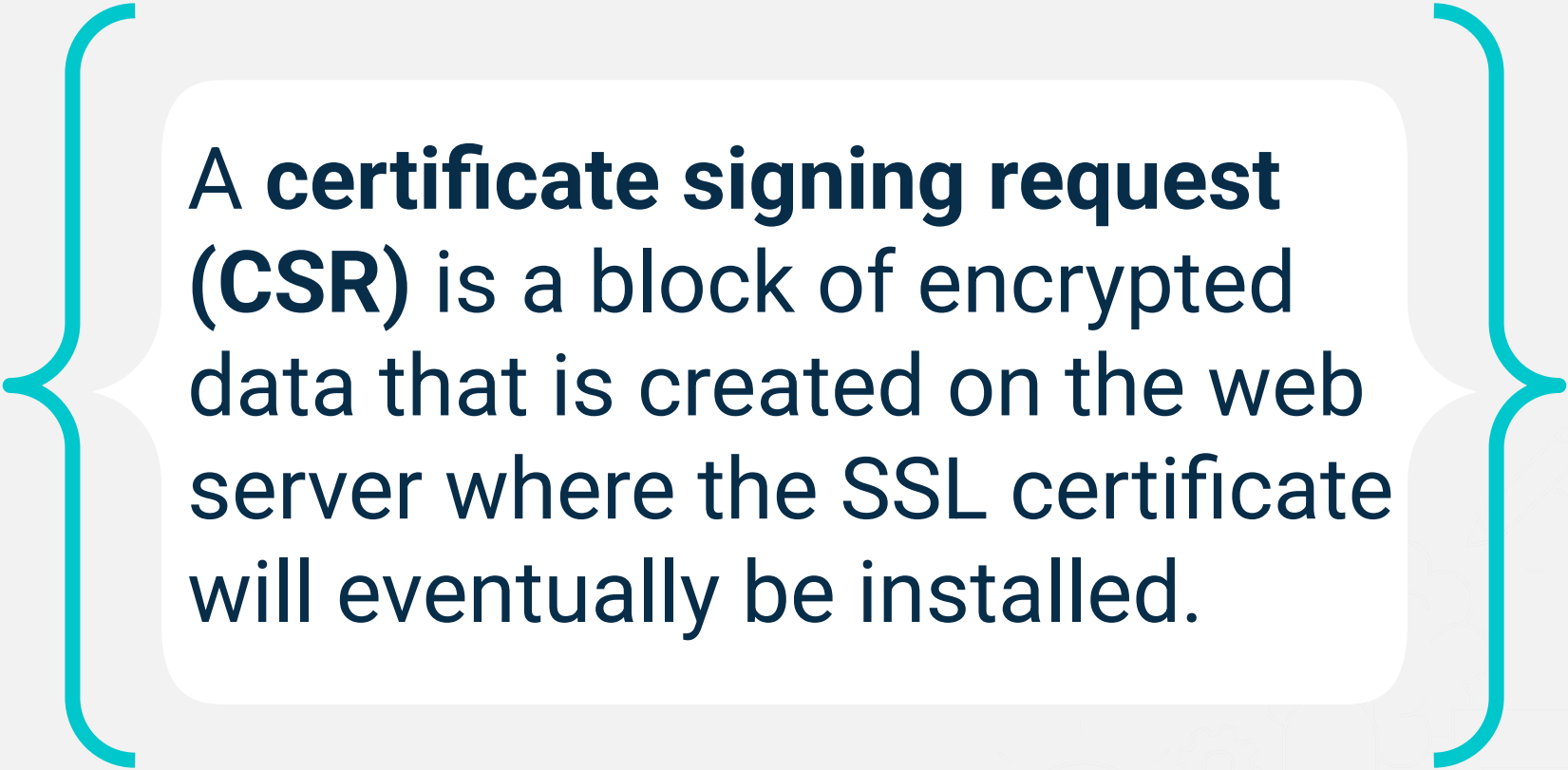
Step 2: Required information



More
Information

The **CA** will require additional information from **widgets.com** in their application.

- Company documents
- Unique IP address
- Certificate Signing Request (**CSR**)

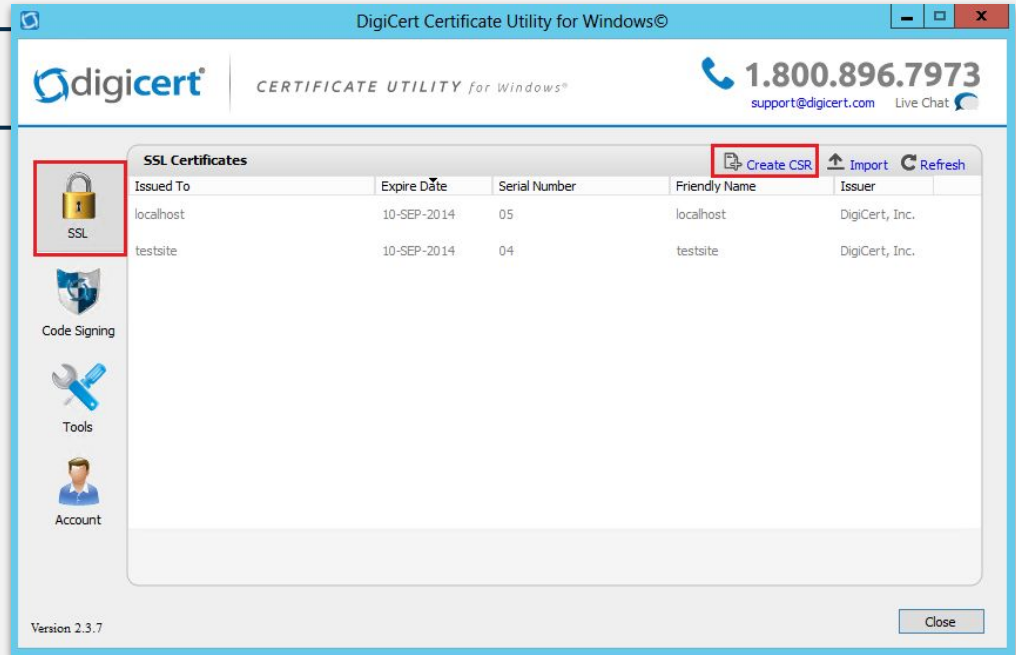


A **certificate signing request (CSR)** is a block of encrypted data that is created on the web server where the SSL certificate will eventually be installed.

Certificate Signing Request

When generating the CSR, a private and public key pair is created.

- Only the public key is sent to the **CA**.
- The private key remains hidden on the web server.





Obtaining an SSL Certificate

Step 3: SSL certificate issued

After the CA validates and approves the information provided in the application, they will send the SSL certificate back to Widgets Corp.

Anyone who views **widgets.com** will be able to see the SSL certificate installed on the website.



https://



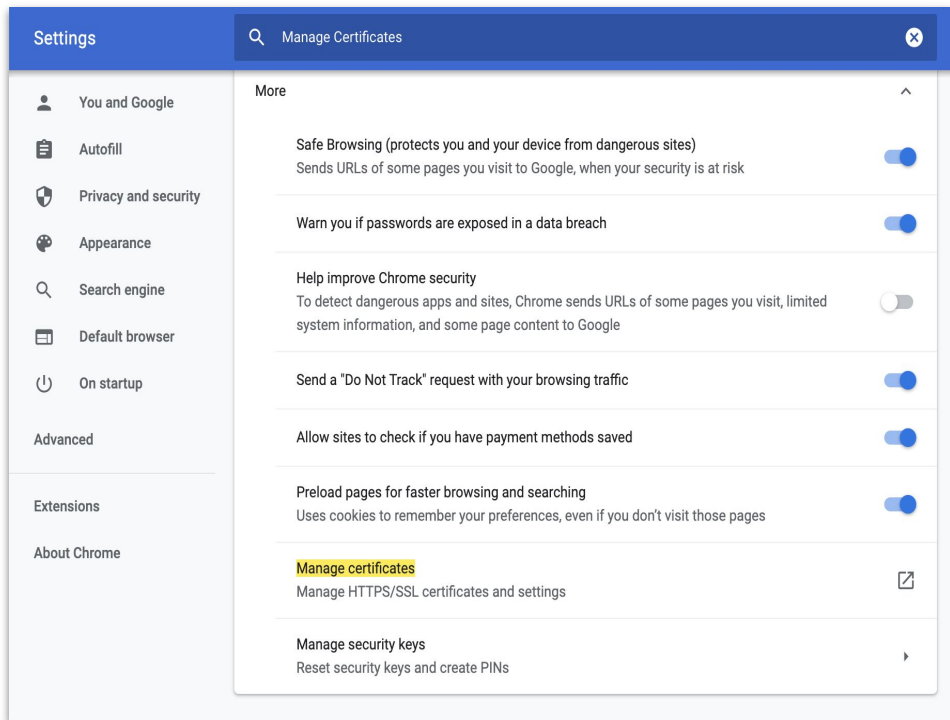
http://

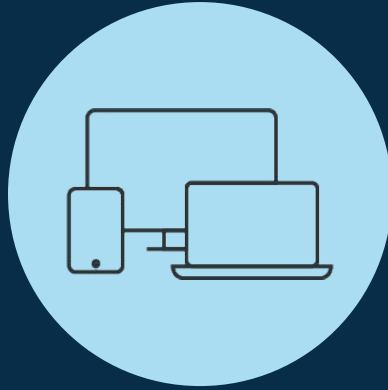


Demonstration Scenario

We will now demonstrate how SSL certificates can be used to validate the authenticity of a website.

- A user receives an email from their bank to go to the following website **www.Superbank!! .com** to update their credentials.
- The user can check the SSL certificate of this suspicious website to determine if it is in fact authentic.





Instructor Demonstration

Valid and invalid **certificates**

SSL in Securing Web Traffic

Servers use SSL to secure web traffic.

01

When we access a secure website, the browser asks the server for certificate details.

02

The server responds with a copy of the SSL certificate and the public key.

03

The browser validates the certificate by checking the expiration date and root CA.

04

The browser uses the server's public key to create, encrypt, and send a session key.

05

The server decrypts the key, sends an acknowledgement, and starts an encrypted session.

06

Secure web traffic begins. Server and browser encrypt/decrypt data with the session key.



Activity

SSL certificates

You will continue to play the role of a security analyst working for the Hill Valley Police Department.

- Several of your fellow officers have received a suspicious email saying that their Hill Valley Police website account has expired and is asking them to log in via a suspicious link.
- Captain Strickland has tasked you with investigating the suspicious link and checking the website certificates to determine if it is legitimate.

Suggested Time

15 minutes



Time's Up!
Let's review



Questions?





Break
15 mins



Cryptographic Attacks

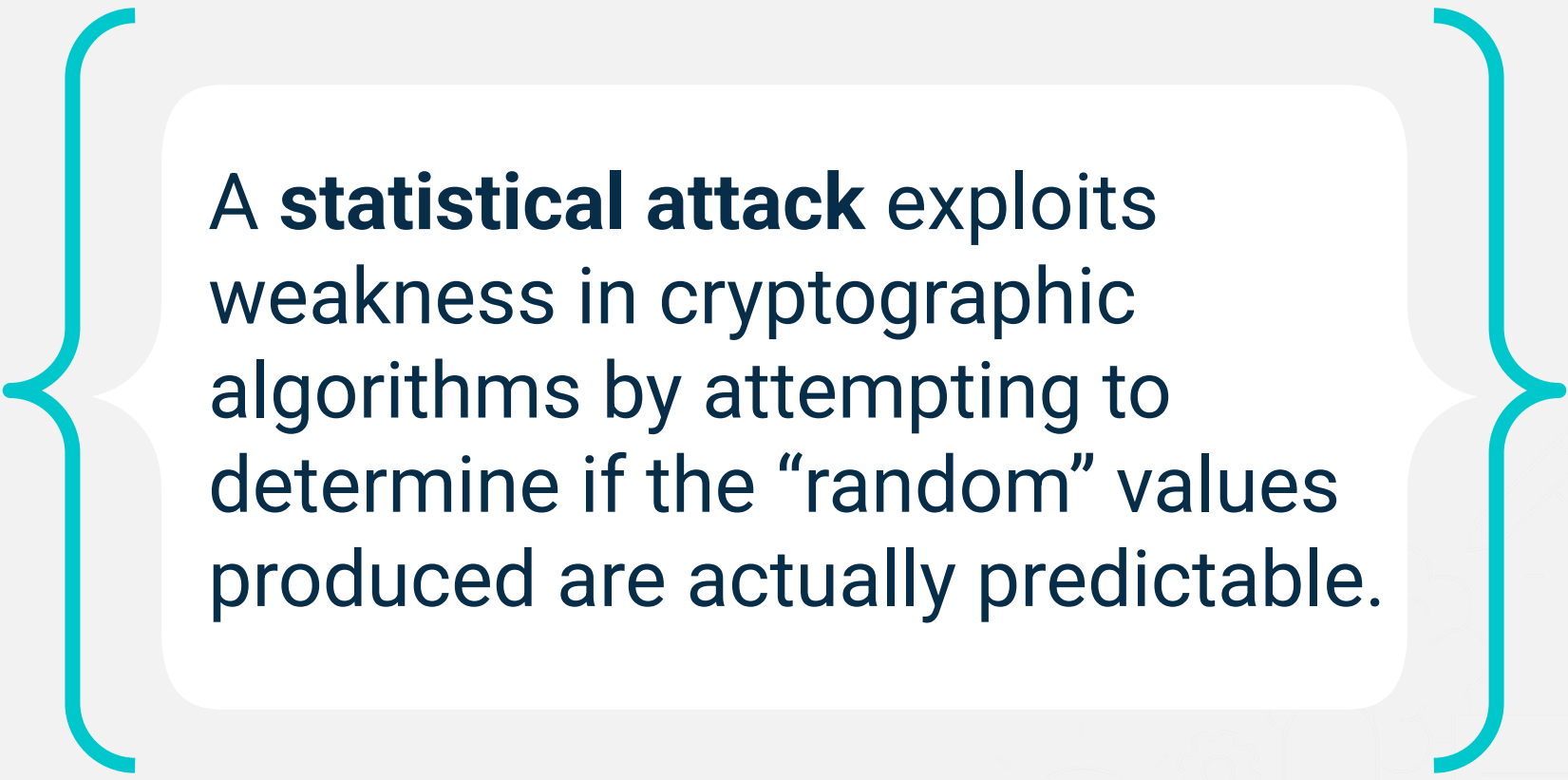


Unfortunately, determined adversaries often find ways to attack these methods through **cryptographic attacks**.

Cybersecurity professionals need to be able to conduct and understand these same attacks to determine if a cryptographic method is secure.



Let's look at several
cryptographic attacks and
the mitigation strategies
to counter them.



A **statistical attack** exploits weakness in cryptographic algorithms by attempting to determine if the “random” values produced are actually predictable.

Statistical Attacks

For example:

Some technology professionals use a token-generation program that creates a random number that they use to securely log in to their computer.

If the number generated is in fact predictable and not random, a hacker can determine the number and access unauthorized data.

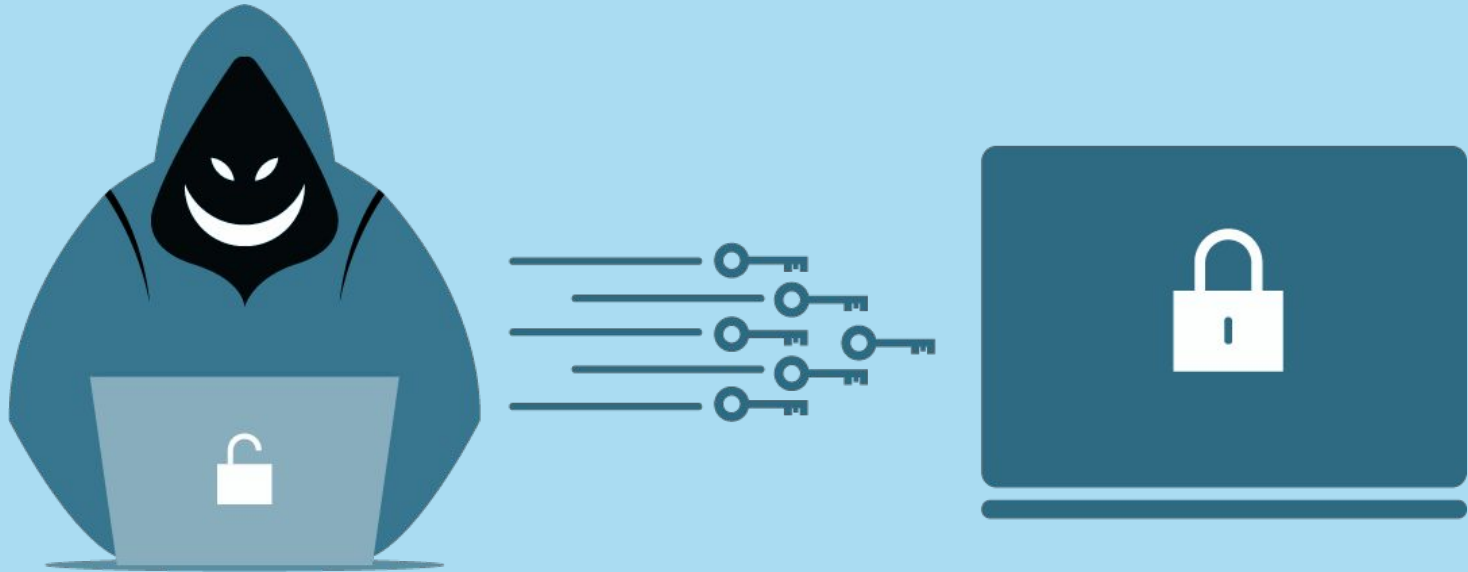


Mitigation

Be sure algorithms are using random values.

Brute Force Attack

In a brute force attack, attackers use many passwords or user and password combinations until one eventually works.



Brute Force Attack

If we wanted to brute force a root account:

User: root, Password: abc123

User: root, Password: 123abc

User: root, Password: 123456

User: root, Password: 654321

User: root, Password: aaaaaa

User: root, Password: bbbbbb

Mitigation

- Apply lockout features to limit the number of login attempts a user has before getting locked out.
- Applications can use firewalls that detect and stop large volumes of attempted logins from a single source IP address.

Birthday attacks

exploit the probability that two separate plaintexts that use the same hash algorithm will produce the same ciphertext.

(Also known as **collision** and **hashing collision**)



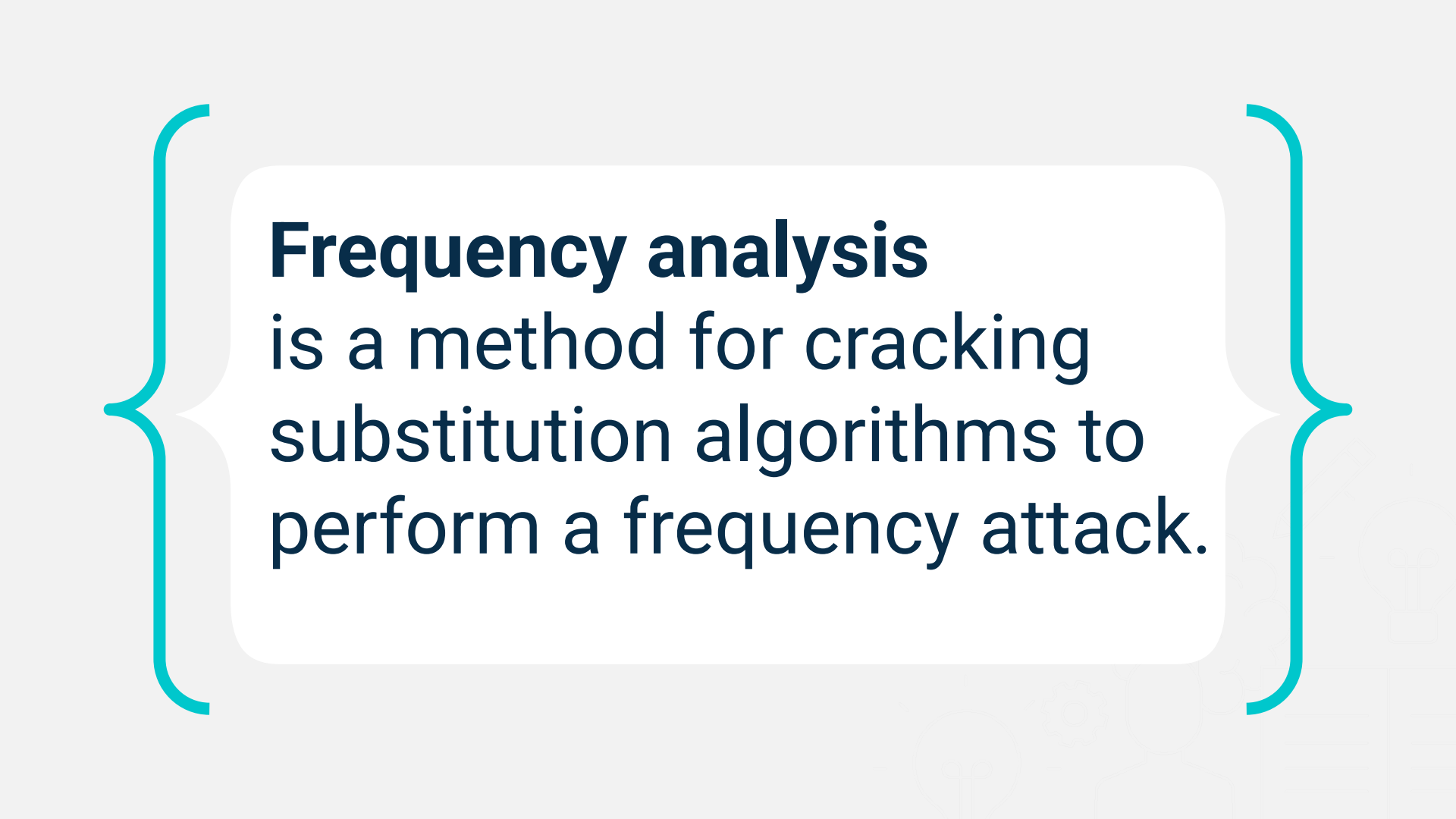
Birthday Attack

The birthday attack is named after a probability theory called the **Birthday Problem**, which states that for a given number of people, the probability that two share a birthday is higher than you would expect (50% for 23, **99.9% for 70**)!



Mitigation

Stronger hashing algorithms limit the possibilities of hashing collision.

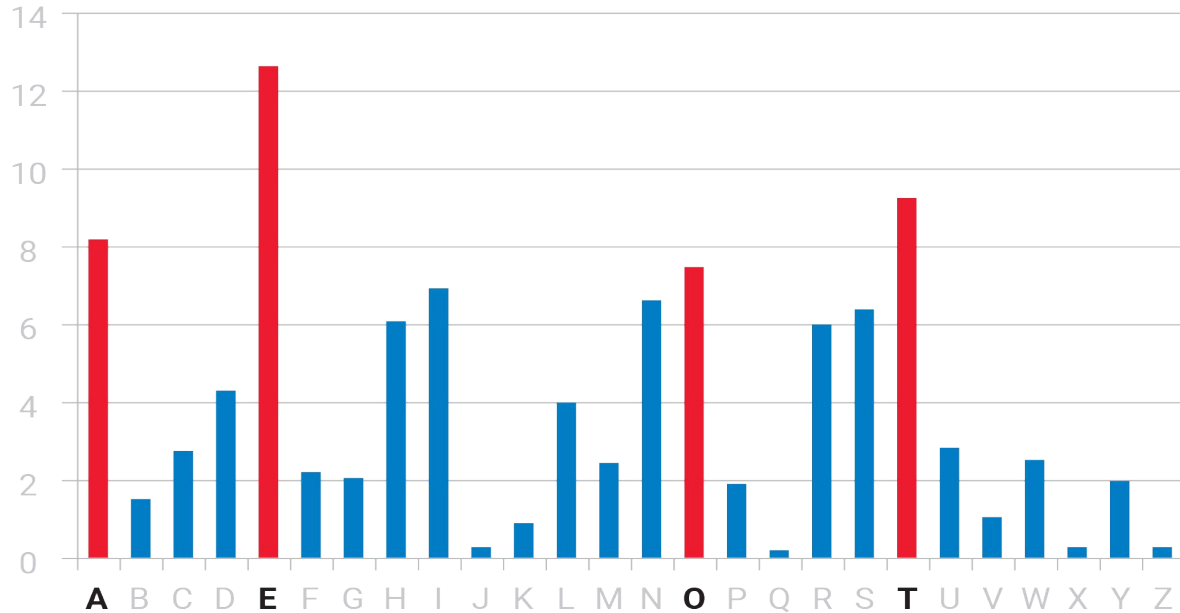


Frequency analysis

is a method for cracking substitution algorithms to perform a frequency attack.

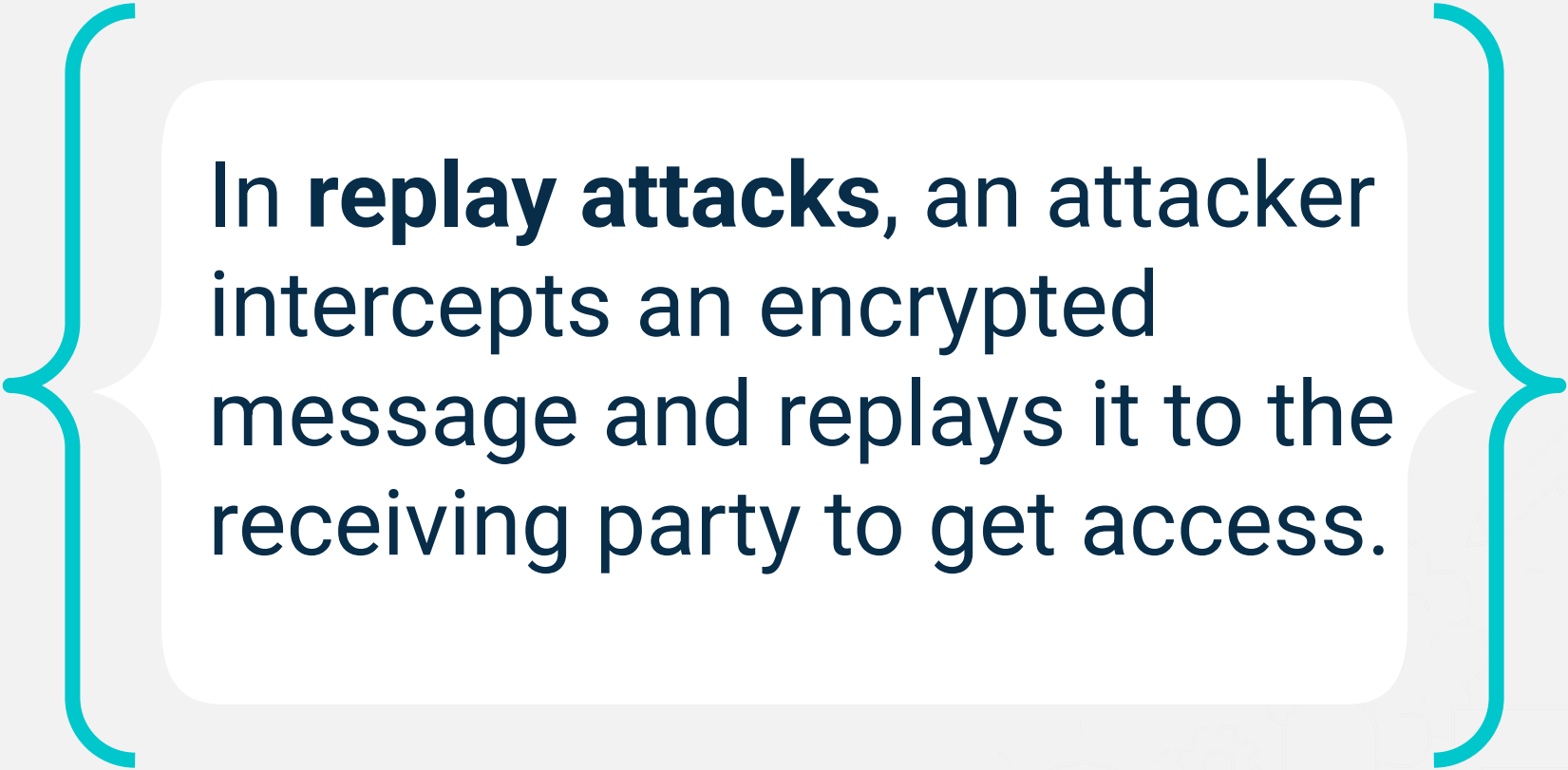
Frequency Analysis

An attacker can note the most frequently used letters in the ciphertext and substitute them with the most frequently used letters in the English language (A, E, O, and T). After inferring the ciphertext, the plaintext can be cracked.



Mitigation

This method targets standard ciphertext ciphers. Mitigate by using more advanced encryption algorithms.



In **replay attacks**, an attacker intercepts an encrypted message and replays it to the receiving party to get access.

Replay Attack

For example:

An attacker can obtain an encrypted signal from a garage door opener.

The attacker can replay the encrypted signal later to open the garage.



Mitigation

Add an expiration time for the encrypted data so it can't be replayed at a later date.

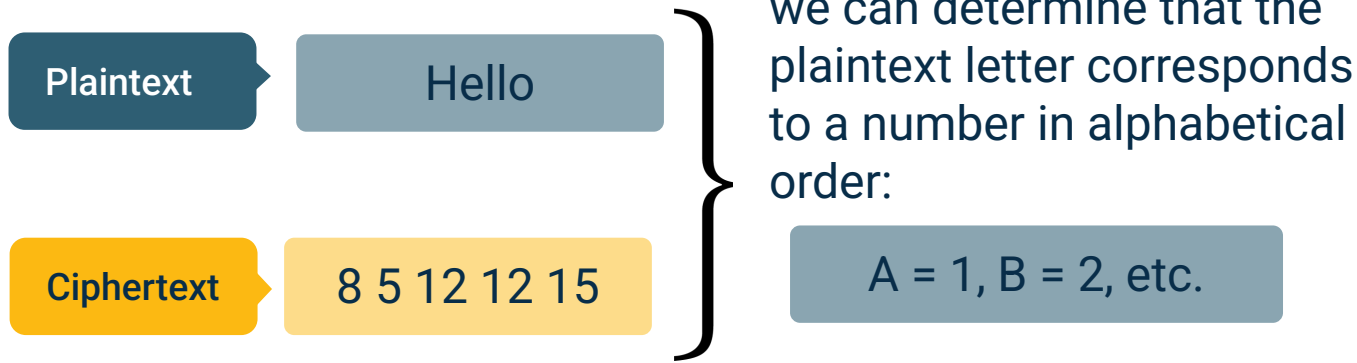
Known-Plaintext Attack

When an attacker has access to a **ciphertext** and its associated **plaintext**, they can analyze the two to determine the encryption algorithm and decrypt future messages.



Known-Plaintext Attack

If we know:



So we know:

7 15 15 4 2 25 5

can be decrypted to:

goodbye

Mitigation

Use advanced encryption and limiting access to ciphertext and associated plaintext.

Chosen-Plaintext Attack

When an attacker has access to the encryption device and program as well as the ciphertext, **but not the associated plaintext**.



Chosen-Plaintext Attack

If we have the ciphertext **act** and the encryption program, we can enter **plaintext** messages into the program:

Plaintext	boy	red	hot
Ciphertext	oby	erd	oht

We can then determine that the transposition cipher is using the **following key**:

$$\{1, 2, 3\} = \{2, 1, 3\}$$

After applying this to our ciphertext **act**, we can determine that the plaintext is **cat**.



To mitigate against
chosen-plaintext attacks, limit
access of the encryption device
and use an advanced encryption
algorithm.

Cryptographic Attacks Review



Attackers use a variety of cryptographic attacks to compromise cryptographic methods and algorithms.



Cybersecurity professionals also use these same cryptographic attacks to determine the security strength of the cryptographic methods being used.



Cryptographic attack types include **statistical**, **brute force**, **birthday**, **frequency**, **replay**, **known-plaintext**, and **chosen-plaintext** attacks.



With each of these attacks, there are also measures that security professionals can use to protect from them.



Activity

Cryptographic attacks

In this activity, you will continue to play the role of a security analyst working for the Hill Valley Police department.

- Captain Strickland shared some news: They have been secretly capturing and monitoring all online activity of the Hill Valley detectives.
- In this activity, you will use cryptographic methods to crack a cipher and reveal a plaintext password.

Suggested Time
20 minutes

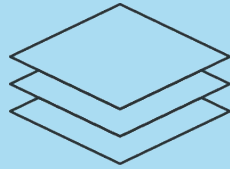


Time's Up!
Let's review

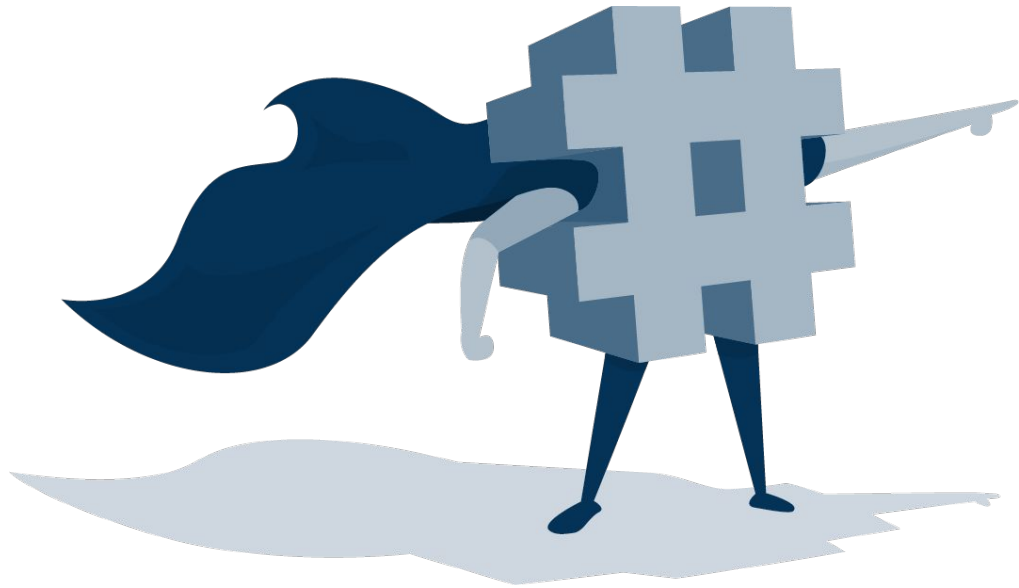


Questions?

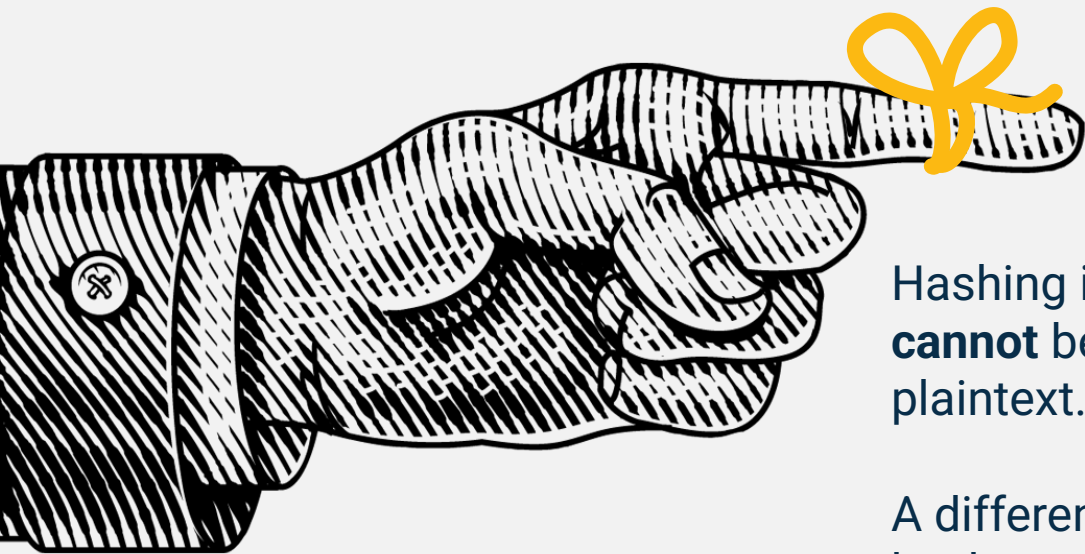




Rainbow Tables and Hashcat



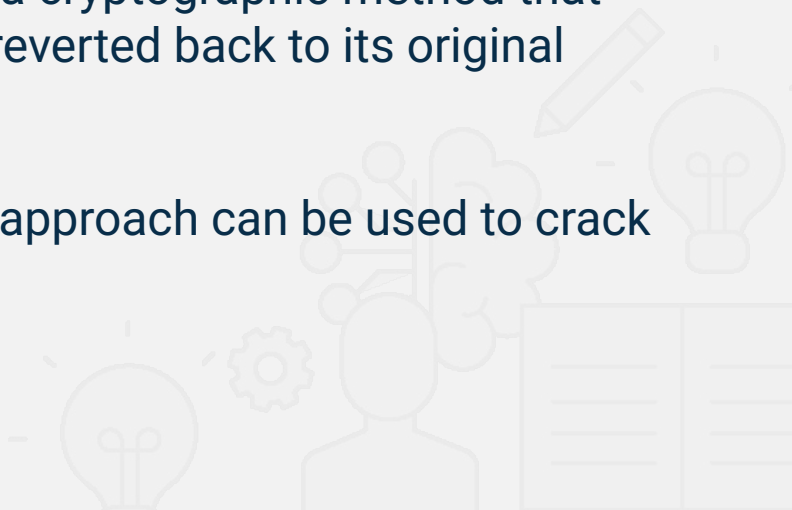
Some types of cryptography, such as **hashing**, require more advanced methods and technologies.



Remember

Hashing is a cryptographic method that **cannot** be reverted back to its original plaintext.

A different approach can be used to crack hashes.





Rainbow Tables

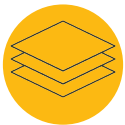
Cracking hashes

Rainbow tables are resources that contain precomputed hashes with the associated plaintext password.

Typically, different hashing algorithms have different rainbow tables.



Plaintext	MD5 Checksum
123456	e10adc3949ba59abbe56e057f20f883e
123456789	25f9e794323b453885f5181f1b624d0b
password	5f4dcc3b5aa765d61d8327deb882cf99
adobe123	7558af202997483d3afef3bb2b5a709d
12345678	25d55ad283aa400af464c76d713c07ad
qwerty	d8578edf8458ce06fbc5bb76a58c5ca4
1234567	fcea920f7412b5da7be0cf42b8c93759
111111	96e79218965eb72c92a549dd5a330112
photoshop	c7c9cfbb7ed7d1cebb7a4442dc30877f
123123	4297f44b13955235245b2497399d7a93



Rainbow Tables

Cracking hashes



Advantage

Finding the correct password is as “Simple” as looking up the hash.

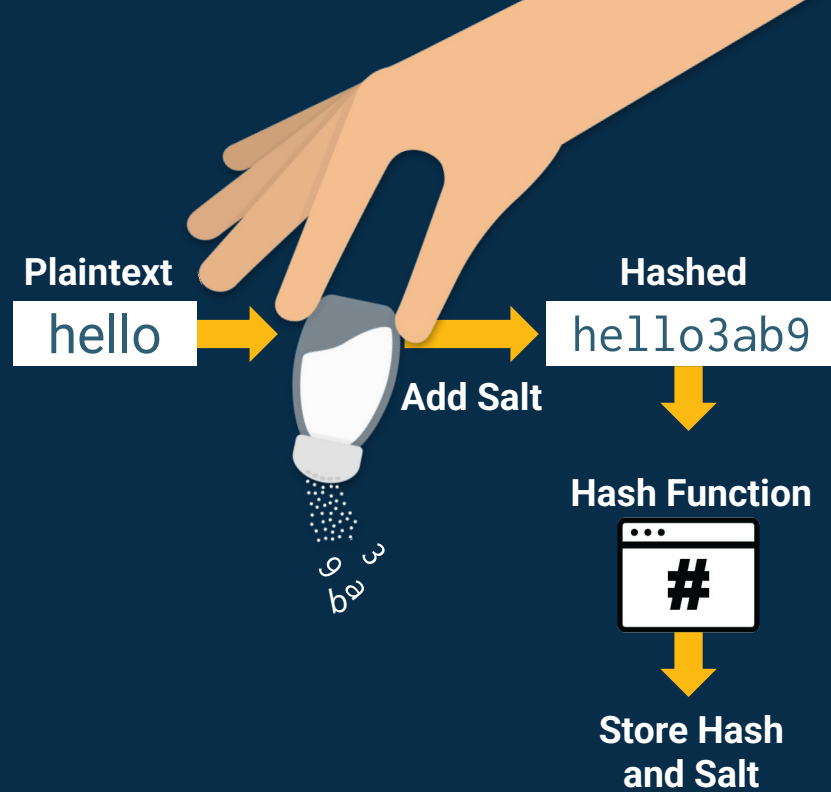
Disadvantage

Some rainbow tables are extremely large and take a lot of storage space and computing power.

Rainbow Tables

We can defend against rainbow tables by **salting**, a cryptographic method of combining salt (a random value) with the plaintext into the hash function.

- Salting is simply adding a random value.
- The output is a salted hash.
- Once the salted hash is saved, the password hash listed in the rainbow table will not match the new salted hash.





Hashcat

Hash cracking tool

Hashcat is a free command-line tool that can automate the cracking of hashes. It uses:

- Dictionary word lists
- Rainbow tables
- Brute force methods
- Multiple hashing algorithms



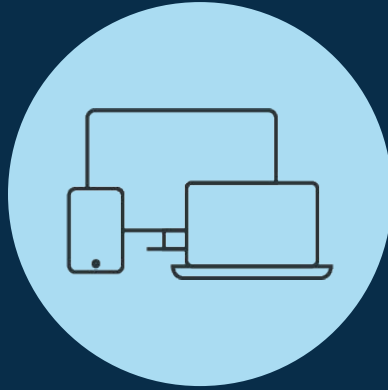
Demonstration Scenario

A cybersecurity professional is tasked with testing the security of a company's website by confirming if they can log in to their website as the root user.

The security professional is able to conduct an attack on the website. With this attack, they capture an unsalted hash value of the root user's password:

ea847988ba59727dbf4e34ee75726dc3.





Instructor Demonstration

Hashcat



Activity

Hashcat

In this activity, you will continue to play the role of a security analyst working for the Hill Valley Police department.

- You found a hash on Detective Tannen's computer that will likely lead you to the password for opening the encrypted file:
f31663d6c912b0b1ced885a6c6bbab7c.
- Use **hashcat** to figure out the plaintext representation of the hash.

Suggested Time
20 minutes



Time's Up!
Let's review



Questions?





Next Class

Introduction to firewalls and network security



Thank You